ATIVIDADE FORMATIVA: SEMANA 2

Estudo de Caso: O Incidente no Banco de Tóquio

O banco de Tóquio está tendo problemas com segurança da informação. Alguém internamente no banco executou uma rotina de software malicioso, este *malware* rapidamente foi replicado aos dispositivos que estavam conectados na rede, inúmeros computadores foram contaminados, inclusive alguns servidores de aplicação que possuem acesso externos. Ao realizar um diagnóstico em um dos computadores contaminados foram identificados alguns dos comportamentos deste *malware*, entre os quais: insere informações no registro do computador, libera determinadas portas no firewall e ainda escala privilégios de administrador na máquina.

O *malware*, ao conseguir acesso a um usuário com privilégios de administrador, altera a senha de todos os usuários. Este *malware* permite que o atacante explore vulnerabilidades, causando danos e obtendo acesso indevido às informações restritas. Porém, um dos maiores problemas está relacionado às portas que foram liberadas no servidor de aplicação que, por sua vez, tem acesso externo. Após o servidor ter sido contaminado e as portas no firewall terem sido abertas, inúmeras tentativas de intrusão ao sistema foram realizadas. Ao observar a origem dos pacotes do tráfego de rede, foram identificados endereços IP de diferentes partes do mundo. Este servidor não pode ficar fora do ar, seria um prejuízo imensurável para o banco. O backup do servidor está sendo restaurado, porém pode levar algumas horas para que o servidor esteja pronto.

Os diretores do banco de Tóquio convocam imediatamente uma reunião, você como mais novo membro da equipe de segurança foi designado como responsável para liderar a equipe de segurança para resolver o problema. A princípio você se sente um pouco ansioso e intimidado, você tem pouco contato com os diretores. Mas, logo lembra que uma oportunidade pode estar surgindo: é a hora de aproveitar!

Sua missão é utilizar todo o conhecimento para conter o incidente e colocar o novo servidor em produção, para isso é necessário observar todos os aspectos e requisitos de segurança da informação. Esta é uma grande oportunidade de mostrar seu desempenho e comunicação com a equipe de segurança, os diretores do banco estão muito apreensivos e querem resultados. Então, é hora de colocar a "mão na massa", desenvolver as atividades propostas e restabelecer os sistemas do Banco de Tóquio!

Roteiro da Atividade:

Está atividade é composta em duas etapas, que consistem: “Análise do estudo de caso” e “Ações e contramedidas ao incidente”.

<u>Análise do estudo de caso:</u>

Analise o estudo de caso do Banco de Tóquio. Acesse o Fórum “Estudo de Caso: Banco de Tóquio”, você deve <u>realizar 3 posts</u>, ou seja, identificar 3 possíveis fatores que contribuíram para o incidente, forneça argumentos que avaliem os seguintes aspectos:

© PUCPR. Todos os direitos reservados. Nenhum texto pode ser reproduzido sem prévia autorização.

a) Tipificação criminal: crimes cibernéticos que podem estar associados ao estudo de caso;
b) Vulnerabilidades e ameaças que podem estar relacionadas ao incidente;
c) Políticas e procedimentos de segurança da informação que foram ignorados ou não foram previstos.

Ações e contramedidas ao incidente:

Na segunda etapa da atividade você deve propor contramedidas e ações que possam auxiliar na prevenção ou mitigação do incidente, bem como preservar as propriedades da segurança da informação. No fórum "Estudo de Caso: Banco de Tóquio", acesse os posts realizados pelos colegas. Selecione 5 posts diferentes, você deve realizar um comentário dentro de cada um destes posts, para fomentar a discussão forneça argumentos que contemplem os seguintes aspectos:

a) Requisitos e boas práticas estabelecidos nas normas ISO 27001 e ISO 27002 no processo de gestão da segurança de informação;
b) Contramedidas em termos de requisitos funcionais estabelecidos no padrão FIPS PUB 200, baseado nas áreas de segurança da informação e suas respectivas atividades;
c) O que a legislação brasileira prevê em relação a este crime virtual.

© PUCPR. Todos os direitos reservados. Nenhum texto pode ser reproduzido sem prévia autorização.